



Software Requirements Specification

Buddhist Pilgrimage Tours Website — for Chinese Tourists
佛教圣地朝圣之旅网站

Version 1.5 — Unified login · Google Auth · Email OTP · Validation layer · Country codes

Client	Astir Passage Pvt. Ltd. (APPL Travel), Patna, Bihar, India
Project Type	Full-stack MERN web application
Prepared for	Developer reference & client approval
Date	19 July 2026 (v1.5 — contact details public again, only the inquiry form requires login; single unified login page; Google OAuth; email OTP verification; schema validation layer; phone country codes)
Source Documents	Buddhist_Pilgrimage_EN_ZH.docx · India_Itinerary_EN_ZH.docx

Table of Contents

1	Introduction — purpose, scope, definitions
2	Overall Description — roles & permissions (RBAC), environment, constraints
3	Website Pages — detailed specification of every page
4	Frontend Requirements — React, routing, bilingual system, styling
5	Backend Requirements — Express API, endpoints, authentication, email
6	Database Design — MongoDB collections and schemas
7	Tour Content Data — full data from both source documents
8	Non-Functional Requirements — performance, security, China access
9	Deployment Architecture
10	Future Enhancements

1. Introduction

1.1 Purpose

This document specifies the complete requirements for a **tourism website** operated by **Astir Passage Pvt. Ltd. (APPL Travel)**, a tour operator based in Patna, Bihar, India. The company organises **Buddhist pilgrimage group tours across India and Nepal exclusively for Chinese-speaking tourists**, providing hotels, meals, air-conditioned transport, monument entrance fees, and a Chinese-speaking guide.

The website's job is to **present the tour packages in both English and Simplified Chinese** and to operate a **Quote & Booking Inquiry system**. There is **no online payment and no fixed package price**: because hotel, transport, and flight costs change over time, all prices shown on the website are **indicative only**. The tourist requests a quote through the inquiry form — or contacts the operator directly on **WhatsApp or by phone call** — and the operator calculates the current price for that group and confirms the booking person-to-person.

1.2 Scope

- Public bilingual website (English / 简体中文) with tour details, itineraries, hotels, and **indicative** pricing.
- **Login / Signup system for all three roles** — tourists can create an account (role `user`) whose details are stored in the database; Owner and Admin log in through the same page. Tourist accounts unlock a profile page, auto-filled inquiry forms, and a "My Inquiries" history.
- **Quote & Booking Inquiry form** that stores requests in a database and notifies the operator by email — **submitting requires a tourist account** (signup/login), so every inquiry is tied to a registered user in the database.
- **Direct contact channels are public**: the operator's contact details (WhatsApp button, phone, WeChat ID, email) are visible to **everyone, including guests**, everywhere on the site. Only the inquiry *form* is behind signup/login.

- **One unified login page (/login) for all three roles** — User, Owner, and Admin all sign in with their credentials on the same page; there is no separate staff login page.
- **Google Sign-In** as an alternative signup/login method, plus **email OTP verification** for accounts registered with email + password.
- **Input validation layer:** every schema (user, inquiry, tour, settings) enforces field rules (length limits, email format, 10-digit phone with country code), and forms show a clear error summary above the form heading naming exactly which field is wrong.
- Direct-contact channels — **WhatsApp and phone call are the primary channels** — plus WeChat ID display and email.
- Private admin panel where the operator manages incoming quote requests.
- Prices stored in the database so the operator can update them any time **without touching code**.
- **Out of scope:** online payment, fixed-price checkout, automatic booking confirmation, user registration/login for tourists, live chat, flight booking engine.

1.3 Definitions

Term	Meaning
MERN	MongoDB + Express + React + Node.js — the technology stack of this project.
SPA	Single-Page Application — the React site loads once and switches pages without reloading.
REST API	The set of HTTP URLs the frontend calls to read/write data (JSON in, JSON out).
JWT	JSON Web Token — a signed token proving a staff member is logged in; carries their role.
RBAC	Role-Based Access Control — permissions determined by role: User (public tourist), Owner (the client / tour operator), Admin (the developer / maintainer). See §2.5.
Inquiry	One submission of the booking form; the core "lead" object of the business.
Bilingual field	A text value stored twice: { en: "De1hi", zh: "德里" } .
Twin sharing	Hotel pricing basis: two guests share one room.
Pax	Travel-industry term for passengers/persons.

1.4 Reference Documents

1. **Buddhist_Pilgrimage_EN_ZH.docx** — 11-Day Buddhist Pilgrimage Journey: full daily itinerary, hotels, pricing, inclusions/exclusions (bilingual).
2. **India_Itinerary_EN_ZH.docx** — 13-Day Buddhist Circuit: group rate tiers, hotels by city, flight supplements, inclusions/exclusions (bilingual).

2. Overall Description

2.1 System Roles (overview)

The system defines **three roles**. Two of them (Owner, Admin) log in through the staff login page; the third (User) never logs in at all. Detailed permissions are specified in §2.5.

Role	Who	Purpose in one line	Login?
User (tourist)	Chinese tourists (primary, usually mobile, may not read English) and international visitors — the public.	Browse tours and request quotes / contact the operator. May optionally sign up for an account (role <code>user</code>) to save their profile and track their inquiries.	Optional — public signup; browsing and inquiries also work without login (C-6)
Owner	The client — the APPL Travel operator in Patna.	Run the business side: manage tourist inquiries and keep indicative prices up to date.	Yes — role <code>owner</code>
Admin	The developer / technical maintainer of the website.	Manage the whole project: everything the Owner can do, plus tours, accounts, site settings, and technical maintenance.	Yes — role <code>admin</code>

2.2 Operating Environment

- **Client:** modern browsers (Chrome, Edge, Safari, WeChat in-app browser) on mobile and desktop. Mobile-first design is mandatory — Chinese users predominantly browse on phones.
- **Server:** Node.js ≥ 18 on any Linux host (Render/Railway/VPS).
- **Database:** MongoDB Atlas cloud cluster (free M0 tier is sufficient at launch), region Mumbai (ap-south-1).

2.3 Design Constraints

#	Constraint	Reason
C-1	No Google services on public pages: no Google Fonts, Google Maps, reCAPTCHA, Google Analytics. Single exception (v1.5): the optional "Sign in with Google" button on the login/signup pages — loaded lazily so a blocked script can never delay page rendering, and always accompanied by the email+password method as the primary path.	Google is blocked in mainland China; the site must never hang for the primary audience. Google Sign-In therefore serves overseas/VPN users only, and Chinese tourists use email + OTP signup (see §3.6–3.7).
C-2	No online payment feature.	Business decision — group bookings are confirmed personally by the operator.
C-3	Every piece of tour content must exist in both English and Simplified Chinese.	Primary audience is Chinese; operator and partners use English.
C-4	Default site language is Chinese; one-click toggle to English; choice remembered.	Serve the primary audience first.

C-5	Chinese text uses system font stack (PingFang SC, Microsoft YaHei, Noto Sans SC local).	No external font downloads (see C-1).
C-6	Browsing and contact details are public; only the inquiry form requires an account. Guests see everything — tours, itineraries, hotels, indicative prices, and all of the operator's contact details (floating WhatsApp button, phone with tap-to-call, WeChat ID, email) on every page. But submitting the Quote & Booking Inquiry form requires signup/login: a guest who opens the form is asked to sign up or log in first, and returns to the pre-filled form afterwards.	Client requirement: leads through the form must correspond to registered accounts in the database, while WhatsApp/phone contact stays frictionless for everyone.
C-6a	The public signup page creates accounts with role user only — the role is hard-coded server-side and never accepted from the signup request. Owner accounts are created only by Admin; Admin accounts only at server setup (seed).	Otherwise anyone on the internet could register as Admin/Owner and take over the dashboard (privilege escalation).
C-7	All displayed prices are indicative, never contractual. Every price table carries a visible disclaimer: "Prices are indicative and vary by season, group size, and current hotel/transport rates. Final quote provided on inquiry. 价格仅供参考，最终报价以咨询为准。"	Hotel, bus, and flight costs change over time; the operator cannot commit to a fixed package price.
C-8	All prices live in the database (not in code) so the operator can revise them at any time without redeploying the website.	Frequent price changes must be cheap to make.

2.3a Pricing Policy (client requirement)

The operator has confirmed that accommodation, hotel, and bus/transport costs **fluctuate over time**, so package prices cannot be fixed. The website therefore follows a **"Request a Quote" model**:

- Tour pages show **"From US\$..." indicative prices** (recommended over hiding prices entirely — a visible ballpark builds trust, filters serious customers, and increases inquiries), always with the C-7 disclaimer.
- No page ever states a binding price. The words "Book now" are avoided in favour of **"Request a Quote / 获取报价"**.
- The final price is calculated fresh by the operator for each group (size, month, current supplier rates) and communicated personally — primarily on **WhatsApp or a phone call**.
- If the operator prefers, any tour's price can be blanked in the database and the card shows "Price on request 价格面议" instead — the layout supports both modes.

2.4 The Quote & Booking Flow (core business process)



Key business rule: the website never confirms a booking or a price by itself. It only delivers qualified leads; pricing and confirmation always happen in the personal WhatsApp/phone conversation, at the operator's current rates.

2.5 Role-Based Access Control (RBAC) — detailed

2.5.1 Role definitions

Role	Detailed responsibilities
------	---------------------------

User (tourist / public visitor)	Anyone who opens the website. Two states: guest (not logged in) and registered (signed up, role <code>user</code>). • As guest (C-6): view all public pages in either language — itineraries, hotels, indicative prices — and all of the operator's contact details: the floating WhatsApp button, phone (tap-to-call), WeChat ID, and email work for guests everywhere on the site. The only thing a guest cannot do is submit the inquiry form — opening it prompts signup/login first. • Signup: creates an account either with email + password (verified by a one-time code emailed to the user, §3.7) or with Google Sign-In (§3.6a). Details stored: name, email, and optional country code + phone / WeChat ID / country (users collection, §6.4). • As registered user (after login): submit the Quote & Booking Inquiry form (auto-filled from the profile, linked to the account); profile page with saved details; "My Inquiries" page showing every submitted inquiry with its current status (new / contacted / booked / closed); set or change own password (§3.8). • Cannot see, reach, or affect anything behind the staff area. All staff routes and APIs answer 403 to a <code>user</code>-role token and 401 to guests.
Owner (the client / tour operator)	The business account. Logs in at <code>/admin</code> with role <code>owner</code>. • Tourist management (core): view all quote inquiries with full contact details; filter by status; move each inquiry through new → contacted → booked → closed; write private notes on an inquiry (e.g. "quoted \$1,350 for Oct, awaiting reply"); delete spam inquiries. • Price management: edit each tour's indicative prices ("From US\$...", price tables, supplements) from the dashboard, since supplier rates change frequently. Changes go live immediately. • Content touch-ups: edit existing tour text (overview, notes, validity date) in both languages. • Own account: change own password. • Cannot: create/delete tours, manage other accounts, change site settings (contact details, WhatsApp number), or access technical infrastructure.
Admin (the developer / project maintainer)	The superuser account. Logs in at the same <code>/admin</code> page with role <code>admin</code>. • Everything the Owner can do (inquiries, prices, content) — so the developer can support the client. • Tour management: create new tour packages, deactivate (soft-hide) or delete tours, re-run/extend seed data, manage tour images. • Account management: create the Owner account, reset the Owner's password when forgotten, deactivate compromised accounts. (Admin accounts themselves are created only via server seed/console — not from the web UI — so a leaked Owner login can never mint new admins.) • Site settings: update global business contact details used across the site (phone, WhatsApp number, WeChat ID, email, address). • Technical maintenance: environment variables, database (Atlas), deployment, backups, dependency updates — performed outside the web UI but part of this role's responsibility.

2.5.2 Permissions matrix

Capability	User (guest)	User (registered)	Owner	Admin
------------	--------------	-------------------	-------	-------

Browse public pages, switch language	✓	✓	✓	✓
Submit quote inquiry (form)	X (redirected to signup/login)	✓ (auto-filled)	—	—
See & use contact channels (WhatsApp, call, WeChat, email)	✓	✓	—	—
Sign up for an account (role "user" forced)	✓	n/a	n/a	n/a
Profile page / edit own details	X	✓	✓	✓
"My Inquiries" history with status	X	✓ (own only)	n/a	n/a
Log in to staff dashboard (/admin)	X	X (403)	✓	✓
View all inquiries & tourist contact details	X	X	✓	✓
Update inquiry status / add private notes	X	X	✓	✓
Delete an inquiry	X	X	✓	✓
Edit tour prices & existing tour text	X	X	✓	✓
Create / deactivate / delete tours	X	X	X	✓
Manage accounts (create Owner, reset passwords)	X	X	X	✓
Edit site settings (contact details, WhatsApp number)	X	X	X	✓
Change own password	n/a	✓	✓	✓
Server, database & deployment maintenance	X	X	X	✓ (outside web UI)

2.5.3 How roles are enforced

- Every account document carries a `role` field: `"user"`, `"owner"`, or `"admin"` (§6.4). Guests (no account) can still browse and submit inquiries.
- **Signup safety (C-6a):** the public signup endpoint hard-codes `role: "user"` on the server. Any role value sent by the client is ignored. Owner accounts are created only from the Admin accounts panel; Admin accounts only by the seed script.
- On login the role is embedded in the JWT payload: `{ id, email, role }`. The frontend reads it to show/hide dashboard sections; the backend re-checks it on **every** protected request — UI hiding alone is never trusted.
- Backend middleware chain: `requireAuth` (valid token?) → `requireRole('admin')` where needed. A valid Owner token calling an admin-only endpoint receives **403 Forbidden**; a missing/expired token receives **401 Unauthorized**.
- The permissions matrix above is the single source of truth; every API route in §5.2 declares which minimum role it requires.

3. Website Pages — Detailed Specification

The site is a React SPA with the following routes. All public pages share a common layout: sticky **navbar** (logo, menu, EN/中文 toggle, Login/Signup links or the account name), **footer** (tagline, quick links, and the operator's full contact details — visible to everyone), and a **floating WhatsApp button** bottom-right on every public page, usable by guests and logged-in users alike (C-6).

Route	Page	Access
/	Home	Public
/tours	Tour listing	Public
/tours/:slug	Tour detail (e.g. /tours/11-day-buddhist-pilgrimage)	Public
/about	About the company	Public
/contact	Quote & booking inquiry form + direct contacts (WhatsApp / call)	Public
/login	The single login page for all three roles (User, Owner, Admin) — email+password or Google Sign-In; redirects by role after success. There is no separate staff login page.	Public
/signup	Tourist signup (creates role "user" accounts only) — email+password with OTP verification, or Google Sign-In	Public
/verify-otp	Email verification screen: enter the 6-digit code sent on signup	Public (pending account)
/account	Tourist area: profile + "My Inquiries" history + set/change password	Requires login (role user)
/admin/dashboard	Role-aware dashboard: inquiries + prices (Owner); + tours, accounts, settings (Admin). Owner/Admin arrive here automatically after logging in at /login.	JWT login; sections gated by role; role "user" gets 403 / redirect home

3.1 Home Page (/)

1. **Hero section** — full-width gradient (maroon → saffron, monk-robe colours), Dharma-wheel mark, headline "Walk in the Footsteps of the Buddha / 追寻佛陀的足迹", one-line pitch, two buttons: *Explore Tours* → /tours and *Plan My Pilgrimage* → /contact.
2. **Featured tours** — cards fetched from `GET /api/tours`; each card shows days/nights, title, route subtitle, short overview, "From US\$..." price, and a link to the detail page. The 11-day tour carries a "Most Popular" badge (`featured: true`).
3. **Why travel with us** — four cards: Chinese-speaking guide · Quality hotels · All meals included · Comfortable A/C transport.
4. **Sacred sites strip** — 8 tiles: Bodh Gaya (enlightenment), Sarnath (first sermon), Lumbini (birthplace), Kushinagar (Mahaparinirvana), Nalanda, Rajgir/Vulture Peak, Shravasti/Jetavana, Agra/Taj Mahal.
5. **Call-to-action band** — "Ready to begin your journey?" with a button to /contact.

3.2 Tours Page (/tours)

- Grid of tour cards (same card component as Home), 2 columns on desktop, 1 on mobile.
- Data source: `GET /api/tours` — returns only tours where `active: true`, featured first.

3.3 Tour Detail Page (/tours/:slug)

The most important page. Data source: `GET /api/tours/:slug`. Sections in order:

1. **Header banner** — days/nights badge, bilingual title, route subtitle, validity note (e.g. "Valid from October 2026").
2. **Overview paragraph.**
3. **Daily itinerary accordion** — one collapsible row per day; Day 1 open by default. Each row shows: day number circle, day title (e.g. "Delhi → Varanasi (by flight) → Sarnath"), and when expanded: the day's activities as *Category: description* lines (Morning / Sightseeing / Evening...), then accommodation city and meals for that day.
4. **Hotels by city table** — columns: City · Nights · Hotel (or similar); header notes the hotel category (e.g. "5-Star or Similar").
5. **Indicative tour cost table** — label/amount rows (per-person rates, group tiers, single supplement), immediately followed by the mandatory C-7 disclaimer line in both languages. If the operator has blanked the prices, this section shows "Price on request 价格面议" instead.
6. **Supplements table** — optional extras (domestic airfare, tipping, guide airfare), same disclaimer.
7. **Cost includes** (green ✓ list) and **Cost does not include** (red X list), side by side on desktop.
8. **Important notes** — bullet list (baggage policy, room availability, airfare disclaimer).
9. **"Request a Quote 获取报价" button** — for a **logged-in user** it opens `/contact?tour=<tourId>` with the form pre-selected and auto-filled. For a **guest** it leads to `/login?next=/contact?tour=...` with the message "Please sign up or log in to request a quote 请注册或登录后获取报价" — after login/signup the tourist lands back on the pre-selected form.
10. **"Chat on WhatsApp" button** — public, works for guests and users alike: opens `wa.me` with a pre-filled bilingual message naming the tour (FE-8).

3.4 About Page (/about)

- Company story: specialist operator in Patna, Bihar — the heart of the Buddhist homeland.
- What we provide: complete packages (hotels, meals, transport, entrance fees), Chinese-speaking guide arrival-to-departure, groups of 12–25+ with group rates, local Bihar expertise.

3.5 Contact / Quote & Booking Inquiry Page (/contact)

Page heading: **"Quote & Booking Inquiry / 获取报价与预订咨询"**, sub-line: "Fill in the form and we will reply with a personal quote within 24 hours — or contact us directly on WhatsApp or by phone." The **direct-contact cards (WhatsApp first, then Call, WeChat, Email) are always visible to everyone**; only the form half of the page is account-gated:

- **Guest view:** the form area shows a locked-state panel — "Create a free account to request a quote 注册免费账户以获取报价" — with **Sign Up** and **Log In** buttons that return the tourist to this page after authentication. The contact cards beside it remain fully usable.

- **Registered-user view:** the full form, auto-filled from the profile (name, email, country code + phone, WeChat ID).
- **Validation errors (FE-10):** if any field fails validation on submit, an error summary appears **above the form heading** listing exactly which fields are wrong and why, in the current language (e.g. "Name must be 20 characters or fewer · Phone must be a 10-digit number"), and each offending input is outlined in red.

Form field	Type	Rule
Full name	text	Required
Email	email	At least one of these three contact methods is required (validated on both frontend and backend)
Phone (with country code)	text	
WeChat ID	text	
Tour of interest	dropdown	Options loaded from API + "General inquiry"; pre-selected via <code>?tour=</code> URL parameter
Number of travellers	number	Optional, min 1
Preferred travel month	text	Optional free text, e.g. "October 2026"
Message / questions	textarea	Optional, max 3000 chars

- On success: form is replaced by a thank-you card ("we will contact you within 24 hours").
- On failure: inline error message; the direct-contact channels remain visible as fallback.
- Beside the form, four **direct-contact cards**: WhatsApp (link `https://wa.me/<number>`), WeChat (displays ID — WeChat has no web deep-link), Call (tel: link), Email (mailto: link).

3.6 Login Page (/login) — the single login page for all roles

- **There is exactly one login page in the whole website.** User, Owner, and Admin all sign in here with their credentials; the server determines the role from the account and the frontend redirects accordingly. No separate staff login URL exists.
- **Method 1 — email + password:** form → `POST /api/auth/login`. The server looks the account up, verifies the bcrypt hash, and returns a JWT containing the role. If the account's email is **not yet verified**, login instead triggers a fresh OTP email and redirects to /verify-otp (§3.7a).
- **Method 2 — "Sign in with Google" button** (§3.6a) — creates the account on first use, logs straight in on later uses. Placed below the email form with a divider ("or 或"). Loaded lazily per C-1 so users in mainland China (where Google is blocked) see the email form instantly and simply ignore the Google button.
- **Redirect by role after success:** `user` → /account (or the `?next=` page they came from) · `owner` / `admin` → /admin/dashboard.
- Link under the form: "New here? Create an account 注册新账户" → /signup.
- Navbar shows "Login 登录 / Sign Up 注册" when signed out, and the account name / "My Account 我的账户" when signed in.

- Wrong credentials → single generic error ("Invalid email or password") — never reveals whether the email exists. Validation errors (empty/invalid email format) appear above the form heading (FE-10).

3.6a Google Sign-In flow (all roles)

- Uses Google OAuth 2.0 (Google Identity Services). The frontend obtains an ID token from Google; the backend verifies it with Google's public keys (`POST /api/auth/google`) — the client's word is never trusted.
- **First-time Google signup:** if no account exists for the verified Google email, one is created with role `user` , `authProvider: "google"` , name and email taken from the Google profile, and **no password**. Email is treated as already verified (Google verified it) — **no OTP is needed**.
- **Returning Google login:** if an account with that email exists (any role — so Owner/Admin can also attach Google to their account email), the user is logged in and receives the normal role-bearing JWT. Everything after login is identical to password login.
- **Password for Google accounts:** a Google-created account can later **set** a password from the profile (§3.8); after that, both login methods work for the same account.
- Role rules are unchanged: Google signup can only ever create role `user` (C-6a).

3.7 Signup Page (/signup) — tourists only

- Two options side by side: the **email + password form**, and the **"Sign up with Google" button** (§3.6a).
- Form fields and validation rules (checked in the browser first, re-checked by the backend validation middleware §5.1a, full rules in §6.6):

Field	Rule	Error message (EN example)
Name*	2–20 characters	"Name must be between 2 and 20 characters"
Email*	Valid email format, unique	"Please enter a valid email address" / "This email is already registered — try logging in"
Password*	Min 8 chars, at least one letter and one number	"Password must be at least 8 characters with a letter and a number"
Confirm password*	Must match password	"Passwords do not match"
Country code + phone	Optional; code from dropdown (default <code>CN +86</code>), number exactly 10 digits	"Phone number must be exactly 10 digits"
WeChat ID	Optional; 6–20 letters, numbers, <code>_</code> or <code>-</code>	"WeChat ID must be 6–20 characters"

- **Country-code dropdown (FE-11):** a searchable selector of international dialing codes (default **+86 China**; +91, +852, +853, +886, +65, +60, +1, +44 ... full ITU list) shown before the phone input. The selected code is stored separately from the number, so the Owner always knows which country a tourist is calling from.
- Validation failures render an **error summary above the form heading** naming each incorrect field (FE-10), bilingual.
- **Role is forced to** `user` **server-side (C-6a)**; there is no role selector on this page.

- On submit, the account is created **unverified** and a 6-digit OTP is emailed → the browser goes to /verify-otp (§3.7a). Only after verification is the user logged in and redirected back to the page they came from (`?next=`) or to /account.
- Since the inquiry form requires an account (C-6), the quote buttons and the contact-page form panel link here — but guests can always use WhatsApp/call directly without signing up.

3.7a Email OTP Verification (/verify-otp)

- After an email+password signup — or a login attempt on a still-unverified account — the server generates a **6-digit code**, stores only its hash with a **10-minute expiry**, and emails the code (via the existing SMTP configuration) with a bilingual message.
- The page shows "We sent a code to *user@example.com* 验证码已发送至您的邮箱", a 6-box code input, a countdown, and a **Resend** button (enabled after 60 s; maximum 5 sends per hour per account).
- `POST /api/auth/verify-otp` checks the code: correct → account marked `emailVerified: true`, JWT issued, user continues; wrong → "Incorrect code, please try again 验证码错误" (maximum 5 attempts per code, then the code is invalidated and a new one must be requested).
- Google-authenticated accounts skip this entirely — Google has already verified the email.
- Unverified accounts cannot log in, cannot submit inquiries, and are auto-deleted after 7 days if never verified.

3.8 Tourist Account Area (/account) — role user

- **Profile tab** — view/edit name, country code + phone, WeChat ID, country (email is the fixed login ID). Field validations and the above-heading error summary follow FE-10/§6.6.
- **Password section — adapts to how the account was created** (applies to all roles, also shown in the staff dashboard for Owner/Admin):
 - **Google-created account (no password yet):** the section is titled "**Set Password 设置密码**" — fields: New password + Confirm password. After setting, the account can log in with either Google or email+password, and the section switches to "Change Password".
 - **Email+password account (or Google account that already set one):** the section is titled "**Change Password 修改密码**" — fields: **Current password, New password, Confirm password**. The current password must verify against the stored hash before the change is accepted.
 - Same password rules as signup (min 8 chars, letter + number); errors listed above the section heading.
- **My Inquiries tab** — every inquiry submitted while logged in, newest first: tour name, travel month, group size, submitted date, and the operator's current status shown as a coloured chip (New 新 / Contacted 已联系 / Booked 已预订 / Closed 已关闭). Read-only — the dialogue itself continues on WhatsApp/WeChat/phone.
- When a logged-in user opens the inquiry form, it is **auto-filled** from the profile, and the submitted inquiry is linked to their account (`user` reference in §6.3).
- Guests visiting /account are redirected to /login.

3.9 Staff Dashboard (/admin/dashboard) — role-aware

Removed in v1.5: the separate staff login page (/admin) no longer exists. Owner and Admin log in at the same /login page as everyone else (§3.6) and are redirected here automatically by their role. Opening /admin/dashboard without a valid Owner/Admin token redirects to /login .

One dashboard, two views: the sections a user sees depend on the role inside their token (and the backend enforces the same rules regardless of what the UI shows).

Visible to both Owner and Admin

- **Inquiries panel (default view)** — status filter tabs (All · New · Contacted · Booked · Closed); inquiry cards newest first with tourist name, status chip, received date/time, tour of interest, group size, travel month, all contact methods, message, and the private **admin note** field (e.g. the price that was quoted).
- **Actions per inquiry:** change status; edit note; delete (with confirmation dialog).
- **Price & content editor** — per tour: edit "From US\$" value, price table rows, supplements, overview/notes text (both languages). Saves via `PUT /api/tours/:id` ; live immediately.
- Change-own-password form; log-out button.

Visible to Admin only

- **Tours manager** — create a new tour, duplicate an existing one, toggle `active` (hide from site without deleting), delete a tour (double confirmation).
- **Accounts panel** — list staff accounts with roles; create an Owner account; reset an Owner's password; deactivate an account. Admin accounts are not creatable from the UI (server-side only) so a stolen Owner login cannot escalate.
- **Site settings panel** — edit the global contact details shown across the site: phone, WhatsApp number, WeChat ID, email, address (both languages).

If an Owner manually opens an admin-only URL or calls an admin-only API, the backend answers **403 Forbidden** — hiding buttons in the UI is convenience, not security (§2.5.3).

4. Frontend Requirements

4.1 Technology

Concern	Choice	Why
Framework	React 18 + Vite	Component model fits repeating structures (day rows, tour cards); Vite gives instant dev reload and small builds.
Routing	react-router-dom v6	SPA routes listed in §3; supports URL params (<code>:slug</code> , <code>?tour=</code>).
Styling	Tailwind CSS v4	Utility classes; custom saffron/maroon palette defined once in CSS <code>@theme</code> .
Internationalisation	react-i18next	All UI strings (buttons, labels, headings) live in one file with <code>en</code> and <code>zh</code> trees.
HTTP client	axios	Single configured instance; automatically attaches the admin JWT header when present.

4.2 The Bilingual System (two halves)

1. **UI strings** (menu items, button text, table headers) — translated via i18next resource files. Switching language re-renders instantly; the chosen language is saved to `localStorage` so it persists on the next visit. **Default: Chinese.**
2. **Content from the database** (tour titles, itinerary text, hotel names) — stored bilingually as `{ en, zh }` objects. A helper function picks the right half:

```
function L(field, lang) {  
  return field?.[lang] || field?.en || field?.zh || '';  
}  
// L(tour.title, 'zh') → "11天佛教圣地朝圣之旅"
```

4.3 Component Inventory

Component	Responsibility
Layout	Wraps public pages: Navbar + page content + Footer + WhatsAppButton.
Navbar	Logo, nav links, EN/中文 toggle, mobile hamburger menu, sticky on scroll.
Footer	Tagline, quick links, full contact details (public), copyright.
WhatsAppButton	Fixed floating button, links to <code>wa.me</code> . Public — visible to guests and logged-in users alike (C-6).
TourCard	Reusable tour summary card (image/emoji, badge, days, title, price, CTA).
Pages	Home, Tours, TourDetail, About, Contact, AdminLogin, AdminDashboard (one file each).

4.4 Frontend Behaviour Requirements

#	Requirement
FE-1	Fully responsive: usable from 360 px phones to desktop; itinerary tables scroll horizontally inside their container if needed.
FE-2	Language toggle switches every visible string without a page reload.
FE-3	Form validation runs client-side first (required name, ≥ 1 contact method) with translated error messages; server re-validates.
FE-4	The contact form pre-selects the tour when opened via "Request a Quote".
FE-5	During development the Vite dev server proxies <code>/api/*</code> to the Express server (no CORS issues); in production the API base URL comes from the <code>VITE_API_URL</code> environment variable.
FE-6	Admin routes never appear in navigation; dashboard redirects to login when unauthenticated.
FE-7	Every price display (cards, cost tables, supplements) renders the bilingual "indicative only" disclaimer (C-7); when price data is absent, "Price on request 价格面议" is shown instead of an empty table.
FE-8	The tour-page WhatsApp button (public — guests included) opens <code>wa.me/<number>?text=...</code> with a pre-filled bilingual message that names the tour, e.g. "Hello, I would like a quote for the 11-Day Buddhist Pilgrimage. 您好, 我想咨询11天佛教朝圣之旅的报价。"
FE-9	Form gating only (C-6): contact details are public everywhere; the inquiry form alone requires login. A guest reaching the form is sent to <code>/login?next=<current page></code> and returned to the pre-filled form after authentication.
FE-10	Validation error display: on any form (signup, login, profile, inquiry, dashboard editors), submit-time validation failures render a bilingual error summary above the form heading naming each incorrect field and the rule it broke (e.g. "Name must be 20 characters or fewer · Phone must be exactly 10 digits"), with the offending inputs outlined in red. Errors come from the shared rules in §6.6 so frontend and backend always say the same thing.
FE-11	Country-code selector: every phone input (signup, profile, inquiry form) is preceded by a searchable international dialing-code dropdown, default +86 (China). Code and 10-digit number are stored as separate fields so the Owner can immediately see the tourist's country.
FE-12	Google button degradation: the "Sign in with Google" button loads lazily and, if Google's script fails to load (mainland China), the button hides silently within 3 s — the email+password flow must never be delayed or broken by it (C-1).

5. Backend Requirements

5.1 Technology

- **Node.js + Express** — REST API, JSON only, stateless (no server sessions).
- **Mongoose** — schema layer over MongoDB (models in §6).
- **jsonwebtoken + bcryptjs** — one auth system for all roles: passwords stored as bcrypt hashes; successful login/signup returns a JWT valid 7 days whose payload includes the account's **role** ({ id, email, role: "user" | "owner" | "admin" }).
- **google-auth-library** — server-side verification of Google ID tokens for the "Sign in with Google" flow (§3.6a); the backend never trusts a token without verifying it against Google's public keys.
- **Email OTP** — 6-digit codes generated server-side, stored as hashes with 10-minute expiry, delivered via the nodemailer/SMTP configuration; rate-limited (5 sends/hour, 5 attempts/code).

5.1a Middleware architecture (separate concerns, separate files)

Each request passes through small, single-purpose middleware functions — validation is deliberately **separate** from authentication so each can change independently:

Middleware	File	Responsibility
validateSignup	middleware/validators.js	Field rules for the signup body (§6.6): name length, email format, password strength, phone 10 digits + known country code, WeChat ID pattern. On failure → 400 with { errors: [{ field, message }] } — the exact structure the frontend renders above the form heading (FE-10).
validateLogin		Email format + non-empty password before any DB lookup.
validateInquiry		Inquiry body rules (§6.6) — name ≤ 20 chars, contact rule, group size range, message length.
validateTour / validateSettings		Dashboard editor payloads: price format, required bilingual fields, settings phone/email formats.
requireAuth	middleware/auth.js	Verifies the JWT; attaches { id, role } to the request; 401 if missing/invalid/expired.
requireVerified		Rejects accounts whose email is not yet OTP-verified (403 with a "verify your email" code the frontend turns into the /verify-otp redirect).
requireRole('owner' 'admin')		Role gate after requireAuth ; 403 if the role is insufficient.

Example chains: POST /api/auth/signup → validateSignup → controller · POST /api/inquiries → requireAuth → requireVerified → validateInquiry → controller · PUT /api/tours/:id → requireAuth →

`requireRole('owner')` → `validateTour` → `controller`.

- **nodemailer** — optional email notification on each new inquiry; if SMTP is not configured the API still works (email step is skipped silently).
- **cors** — allows only the configured frontend origin (`CLIENT_URL`).

5.2 API Endpoints (with minimum required role)

Method & Path	Min. role	Purpose	Request / Response essentials
GET <code>/api/health</code>	User (public)	Uptime check	→ { status: "ok" }
GET <code>/api/tours</code>	User (public)	List active tours for cards	→ array of { slug, title, subtitle, days, nights, overview, priceFrom, coverImage, featured }
GET <code>/api/tours/:slug</code>	User (public)	Full tour document	→ everything incl. itinerary, hotels, pricing...; 404 if unknown/inactive
POST <code>/api/inquiries</code>	User (registered)	Submit quote/booking form	Chain: <code>requireAuth</code> → <code>requireVerified</code> → <code>validateInquiry</code> → <code>controller</code> . Anonymous requests get 401 (C-6). ← { name*, email/phone (country code + 10 digits)/wechatId (≥1), tourId?, groupId?, travelDate?, message? } → 201 + id. Field rules per §6.6 (400 with per-field errors on failure); snapshots tour title; links the inquiry to the authenticated user automatically (user id from the token, never from the body); triggers email.
POST <code>/api/auth/signup</code>	User (public)	Tourist account creation (email + password)	Chain: <code>validateSignup</code> → <code>controller</code> . ← { name*, email*, password*, phoneCountryCode?, phone?, wechatId?, country? } → 201, account created unverified , OTP emailed. Role hard-coded to "user" server-side (C-6a) ; duplicate email → 409; validation failure → 400 { errors:[{field,message}] }.
POST <code>/api/auth/verify-otp</code>	User (public)	Verify the emailed 6-digit code	← { email, code } → marks emailVerified, returns { token, ..., role }. Max 5 attempts per code; expired/exhausted → request a new code.
POST <code>/api/auth/resend-otp</code>	User (public)	Send a fresh code	← { email } → 200. Rate-limited: 60 s cooldown, 5/hour.
POST <code>/api/auth/google</code>	User (public)	Google Sign-In (signup + login)	← { idToken } → server verifies with Google; creates role-"user" account on first use (authProvider "google", emailVerified true, no password) or logs into the existing account with that email (any role) → { token, name, email, role }.
POST <code>/api/auth/login</code>	— (credentials)	Login for all roles — the only login endpoint	Chain: <code>validateLogin</code> → <code>controller</code> . ← { email, password } → { token, name, email, role }; 401 on bad credentials (generic message); unverified email → 403 + fresh OTP sent (frontend redirects to <code>/verify-otp</code>).

POST /api/auth/set-password	User (registered)	First password for a Google-created account	← { newPassword } → 200; rejected with 409 if the account already has a password (use change-password instead).
GET /api/auth/me	User (registered)	Current profile	→ { name, email, phone, wechatId, country, role }
PUT /api/auth/me	User (registered)	Update own profile	← { name?, phone?, wechatId?, country? } → updated profile (email & role not changeable here)
GET /api/inquiries/mine	User (registered)	"My Inquiries" history	→ array of own inquiries only (matched by user reference), with status
GET /api/inquiries?status=	Owner	List inquiries, newest first	→ array; optional status filter
PATCH /api/inquiries/:id	Owner	Change status / private note	← { status?, adminNote? } → updated inquiry
DELETE /api/inquiries/:id	Owner	Remove an inquiry	→ confirmation
PUT /api/tours/:id	Owner	Edit prices / text of an existing tour	← partial tour fields → updated tour
PATCH /api/auth/password	User (registered)	Change own password (any logged-in role)	← { currentPassword, newPassword } → confirmation
POST /api/tours	Admin	Create a new tour	← full tour document → 201 + tour
DELETE /api/tours/:id	Admin	Delete a tour	→ confirmation (dashboard asks twice)
GET /api/accounts	Admin	List staff accounts	→ array of { email, name, role, active } (never password hashes)
POST /api/accounts	Admin	Create an Owner account	← { email, name, password } → 201. Role is forced to "owner" server-side — admin accounts cannot be created via the API.
PATCH /api/accounts/:id	Admin	Reset password / deactivate an Owner account	← { newPassword? , active? } → confirmation
GET /api/settings	User (public)	Site contact details (phone, WhatsApp, WeChat, email, address)	Public again in v1.5 (C-6): contact details are visible to everyone. → settings object consumed by footer / contact page / WhatsApp button.
PUT /api/settings	Admin	Update site contact details	← settings fields → updated settings

Enforcement rule: "Min. role Owner" means Owner *and* Admin may call it; "Min. role Admin" means Admin only. Anonymous requests to any staff endpoint get 401; an Owner token on an Admin-only endpoint gets 403. The backend enforces this on every request — never only the UI.

5.3 Environment Variables (server/.env)

Variable	Purpose
MONGO_URI	MongoDB Atlas connection string (secret — never committed to Git).
JWT_SECRET	Random string used to sign admin tokens.
PORT	API port (default 5000).
CLIENT_URL	Frontend origin allowed by CORS.
ADMIN_EMAIL / ADMIN_PASSWORD	Initial Admin account (role "admin" — the developer) created by the seed script.
OWNER_EMAIL / OWNER_PASSWORD	Initial Owner account (role "owner" — the client) created by the seed script.
SMTP_HOST / SMTP_PORT / SMTP_USER / SMTP_PASS / NOTIFY_EMAIL	Required in v1.5 — used for OTP verification emails (signup cannot complete without them) as well as inquiry notifications.
GOOGLE_CLIENT_ID / GOOGLE_CLIENT_SECRET	Google OAuth 2.0 credentials from Google Cloud Console (APIs & Services → Credentials) for the "Sign in with Google" flow. The client ID is also exposed to the frontend as <code>VITE_GOOGLE_CLIENT_ID</code> .

5.4 Seed Script

`npm run seed` inserts/updates (upserts by slug) the two tour packages with the full bilingual content of §7, creates the initial **Admin** account (role `admin`, credentials from `ADMIN_EMAIL / ADMIN_PASSWORD` env vars) and the initial **Owner** account for the client (role `owner`, from `OWNER_EMAIL / OWNER_PASSWORD`), and writes the default settings document. Safe to run repeatedly — existing accounts are never overwritten.

6. Database Design (MongoDB)

Database name: `app1_travel` on a MongoDB Atlas cluster (free M0, region Mumbai). Three collections. MongoDB is chosen because a tour is naturally **one nested document** (itinerary days inside the tour, activities inside each day) — no join tables needed.

6.1 The bilingual field pattern

```
// used for every human-readable text value in the tours collection
{ en: "Visit Sarnath, where the Buddha gave his first sermon...",
  zh: "参观鹿野苑，佛陀悟道后首次说法之地..." }
```

6.2 Collection: tours

Field	Type	Description
slug	string, unique	URL identifier, e.g. "11-day-buddhist-pilgrimage"
title / subtitle / overview	bilingual	Name, route line, intro paragraph
days / nights	number	e.g. 11 / 10
itinerary[]	array	Per day: { day, title(bi), activities[{ category(bi), description(bi) }], accommodationCity(bi), meals(bi) }
hotels[]	array	{ city(bi), nights, hotelName(bi) }
hotelCategory	bilingual	"5-Star or Similar" etc.
pricing[] / supplements[]	array, optional	{ label(bi), amount(bi) } — amount kept as text to allow "US\$ 6 per person per day". Indicative only (C-7) ; the operator updates these directly in the database whenever supplier rates change — no code change or redeploy needed (C-8). May be left empty → page shows "Price on request".
priceFrom	number, optional	Numeric USD for "From \$..." on cards and sorting; omit to display "Price on request 价格面议"
includes[] / excludes[]	array	{ item(bi), details(bi) }
notes[]	array of bilingual	Baggage policy, disclaimers...
coverImage / images[]	string URLs	Photos (can be added later via Cloudinary)
validFrom	bilingual	"Valid from October 2026"
featured / active	boolean	Badge on cards / soft-hide a tour without deleting
createdAt / updatedAt	dates	Automatic timestamps

6.3 Collection: inquiries

Field	Type	Description
name	string, required, ≤ 20 chars	Tourist's name (validated per §6.6)
email / phone / wechatId	string	At least one required (enforced by validateInquiry). Email must be valid format; phone exactly 10 digits with its own <code>phoneCountryCode</code> field (dropdown, default +86) so the Owner knows the caller's country; WeChat ID 6–20 chars.
phoneCountryCode	string, e.g. "+86"	International dialing code accompanying the phone number (FE-11)
country	string	Default "China"
tour	ObjectId → tours	Reference to the selected tour (optional)
user	ObjectId → users, required	Always set — inquiries can only be submitted by logged-in tourists (C-6), and the id is taken from the JWT server-side. Powers the "My Inquiries" page.
tourTitle	string	Snapshot of the tour name — inquiry stays readable even if the tour is edited/removed
groupSize	number ≥ 1	Number of travellers
travelDate	string	Free text ("October 2026") — groups plan by month
message	string ≤ 3000	Questions / requirements
status	enum	new → contacted → booked → closed
adminNote	string	Operator's private note
createdAt	date	Automatic — shown as "Received" in the dashboard

6.4 Collection: users (all accounts — User, Owner, Admin)

One collection stores every account; the `role` field distinguishes them. Tourist signups land here with role "user" — this is where "all the details are stored in the database".

Field	Type	Description
email	string, unique, required	Login username (fixed after signup)
passwordHash	string, conditional	bcrypt hash — plain passwords are never stored. Required when <code>authProvider</code> is "local"; absent for Google-created accounts until the user sets one (§3.8).
name	string, required, 2–20 chars	Display name

role	enum: "user" "owner" "admin"	Drives all permissions (§2.5). Embedded in the JWT at login; checked by backend middleware on every protected request. Public signup (email or Google) can only ever produce "user" (C-6a).
authProvider	enum: "local" "google"	How the account was created. Decides whether the profile shows "Set Password" (google, no password yet) or "Change Password" (local, or google after setting one) — §3.8.
googleId	string, optional, unique-sparse	Google's stable subject id, stored on first Google sign-in
emailVerified	boolean, default false	Set true by OTP verification (§3.7a) or immediately for Google accounts. Unverified accounts cannot log in or submit inquiries; auto-deleted after 7 days.
otpCodeHash / otpExpiresAt / otpAttempts	string / date / number	Current OTP (hashed), its 10-minute expiry, and failed-attempt counter (max 5). Cleared after successful verification.
phoneCountryCode	string, e.g. "+86"	International dialing code from the dropdown (FE-11) — tells the Owner the tourist's country at a glance
phone	string, optional, exactly 10 digits	Tourist's phone number (without country code) — used to auto-fill the inquiry form
wechatId	string, optional	Tourist's WeChat ID — used to auto-fill the inquiry form
country	string, default "China"	Tourist's country
active	boolean, default true	Admin can deactivate an account; inactive accounts cannot log in
createdAt / updatedAt	dates	Automatic timestamps (signup date shown in nothing public)

6.5 Collection: settings (single document)

Field	Type	Description
phone	string	Business phone (also used for tap-to-call)
whatsapp	string	WhatsApp number in international digits (for wa.me links and the floating button)
wechatId	string	WeChat ID shown on contact cards
email	string	Business email (mailto links + inquiry notifications)
address	bilingual	Business address for the footer

Editable by Admin only (PUT /api/settings); read publicly by the frontend so the footer, contact page, and WhatsApp button always show current details without a redeploy. Settings values are validated on save (validateSettings): phone/WhatsApp must be digits with a country code, email must be valid format — a typo here would break every contact link on the site.

6.6 Validation rules — single source of truth

These rules are enforced **twice**: in the browser for instant feedback, and by the backend validation middleware (§5.1a) for security — the backend is authoritative. Every failure produces a per-field message; the frontend renders them as a bilingual summary **above the form heading** with the offending inputs outlined in red (FE-10).

Collection / form	Field	Rule	Error message (EN — mirrored in 中文)
users (signup / profile)	name	Required, 2–20 characters	"Name must be between 2 and 20 characters"
	email	Required, RFC-style format (x@y.z), unique, lowercase	"Please enter a valid email address" / "This email is already registered"
	password	Required (local accounts), ≥ 8 chars, ≥ 1 letter and 1 number	"Password must be at least 8 characters with a letter and a number"
	phoneCountryCode	Must be a known ITU dialing code from the dropdown	"Please select a country code"
	phone	Optional; exactly 10 digits, numbers only	"Phone number must be exactly 10 digits"
	wechatId	Optional; 6–20 chars, letters/numbers/_/-	"WeChat ID must be 6–20 characters"
inquiries (quote form)	name	Required, ≤ 20 characters	"Name must be 20 characters or fewer"
	email	Optional; valid format if given	"Please enter a valid email address"
	phone (+ code)	Optional; exactly 10 digits, country code required with it	"Phone number must be exactly 10 digits"
	contact rule	At least one of email / phone / WeChat ID	"Please provide at least one contact method"
	groupSize	Optional; integer 1–100	"Group size must be between 1 and 100"
	message	Optional; ≤ 3000 characters	"Message is too long (max 3000 characters)"

tours (dashboard editor)	slug	Required, unique, lowercase letters/numbers/hyphens	"Slug may only contain lowercase letters, numbers and hyphens"
	title.en / title.zh	Required, ≤ 120 characters each	"Title is required in both languages"
	days / nights	Required integers, 1–60; nights = days – 1 warning	"Days must be between 1 and 60"
	priceFrom	Optional; positive number ≤ 100,000	"Price must be a positive number"
settings (admin panel)	phone / whatsapp	Digits with leading country code, 8–15 digits total (E.164)	"Enter the number with country code, digits only"
	email	Valid format	"Please enter a valid email address"
	wechatId	6–20 chars, letters/numbers/_/-	"WeChat ID must be 6–20 characters"

7. Tour Content Data (from source documents)

Pricing status: all rates below come from the operator's source documents and serve as the **initial indicative baseline** loaded by the seed script. Per constraint C-7/C-8 they are shown on the website only as "From US\$..." figures with the bilingual disclaimer, and the operator revises them in the database as supplier costs change. They are never a committed selling price.

7.1 Package A — 11-Day Buddhist Pilgrimage Journey · 11天佛教圣地朝圣之旅

Route: Shanghai · Delhi · Varanasi · Bodh Gaya · Lumbini · Agra （上海 · 德里 · 瓦拉纳西 · 菩提伽耶 · 蓝毗尼 · 阿格拉）

Flights: outbound MU563 Shanghai (PVG) → Delhi 12:50–17:45; return MU564 Delhi → Shanghai 19:55–04:10 (+1).

Validity: from October 2026 · **Hotels:** 5-star or similar · **Meals:** 10 breakfasts, 10 lunches, 11 dinners.

Daily itinerary

Day	Route 行程	Highlights	Stay
1	Shanghai → Delhi 上海 → 德里	Flight MU563; welcome dinner 欢迎晚餐	Delhi
2	Delhi → Varanasi (flight) → Sarnath 德里 → 瓦拉纳西 → 鹿野苑	First sermon site: Dhamek Stupa, Chinese Temple, Five Disciples' Stupa, museum; evening Ganga Aarti 恒河晚祷	Varanasi
3	Varanasi → Bodh Gaya 瓦拉纳西 → 菩提伽耶	Sunrise Ganges boat ride 恒河日出乘船; Bharat Mata & Durga temples; drive to Bodh Gaya	Bodh Gaya
4	Bodh Gaya 菩提伽耶 — Path to Enlightenment	Mahabodhi Temple 摩诃菩提寺, Great Buddha, Pragbodhi Hill, Uruvela Forest, Sujata Village; international monasteries (Thailand, Myanmar, Sri Lanka, Japan, China Han & Tibetan)	Bodh Gaya
5	Bodh Gaya → Rajgir → Nalanda → Patna 王舍城 → 那烂陀 → 巴特那	Vulture Peak 灵鹫山; Nalanda university ruins 那烂陀遗址	Patna
6	Patna → Vaishali → Kushinagar 吠舍离 → 拘尸那伽	Ashokan Pillar, Relic Stupa, Ananda Stupa, Monkey Pond; Mahaparinirvana sites: Reclining Buddha, Mahaparinirvana Stupa, Shuanglin Temple 双林寺	Kushinagar
7	Kushinagar → Lumbini (Nepal) 蓝毗尼 (尼泊尔)	Cross-border drive; Lumbini Garden, Maya Devi Temple 摩耶夫人庙, Ashokan Pillar, Chinese Monastery	Lumbini
8	Lumbini → Shravasti 舍卫城	Jetavana Monastery 祇陀林 (Amitabha Sutra site); Ananda Bodhi Tree	Shravasti
9	Shravasti → Lucknow 勒克瑙	Setavya "Buddha Airport" 佛陀机场; drive to Lucknow	Lucknow
10	Lucknow → Sankasya → Agra 桑迦施 → 阿格拉	Buddha's descent from Tavatimsa Heaven 忉利天; Elephant Capital Pillar; drive to Agra	Agra

11	Agra → Delhi → Shanghai	Taj Mahal 泰姬陵 & Agra Fort 阿格拉堡; farewell dinner; flight MU564	On board 机上
----	-------------------------	---	----------------

Hotels (5-star or similar 五星级或同等级)

City	Hotel
Delhi 德里	Hyatt Centric / Radisson Kaushambi or equivalent
Varanasi 瓦拉纳西	The Madin or equivalent
Bodh Gaya 菩提伽耶	Mahabodhi or equivalent
Patna 巴特那	Hotel Maurya or equivalent
Kushinagar 拘尸那伽	Imperial or equivalent
Lumbini 蓝毗尼	Crystal Garden or equivalent
Shravasti 舍卫城	Imperial or equivalent
Lucknow 勒克瑙	Ramada by Wyndham Lucknow or equivalent
Agra 阿格拉	Agra Crystal Sarovar / Ramada or equivalent

Pricing (valid from October 2026)

Item	Amount
Minimum group size 最低成团人数	12 paying passengers
Cost per person, twin sharing 每人 (双人共住)	US\$ 1,285
Single room supplement 单人间附加费	US\$ 705
Domestic airfare supplement (Varanasi–Delhi) 国内机票附加费	US\$ 90
Tipping (12-pax group) 小费	US\$ 6 per person per day

Includes / Excludes

✓ Included 费用包含	X Not included 费用不含
All transfers & sightseeing by A/C vehicle · 10 nights twin-sharing · all meals (10B/10L/11D) · monument entrance fees · driver allowance, fuel, parking, tolls, interstate taxes · Chinese-speaking guide arrival-to-departure · 1 bottle mineral water/person/day · government service tax	Any international or domestic airfare · guide services on leisure/shopping days · airport taxes · meals not specified · camera/video entrance charges · personal expenses (drinks, laundry, calls) · tips to driver, guide, hotel staff

7.2 Package B — 13-Day Buddhist Circuit, India · 印度佛教圣地13天

Duration: 12 nights / 13 days. Extended circuit with overnight stays in Rajgir and Vaishali (2 nights Delhi, 2 nights Bodhgaya). Transport by 41-seater A/C coach.

Group rates (net, per person) 团体净价

Paying pax 付费人数	Rate
15 + 01	USD 1,032 per person
20 + 01	USD 975 per person
25 + 01	USD 941 per person
Single room supplement 单人间附加费	USD 652 per room

Hotels by city 城市酒店安排

City	Nights	Hotel envisaged or similar
Delhi 德里	2	Hotel Vivanta New Delhi, Dwarka
Varanasi 瓦拉纳西	1	Radisson / Madin / Clarks
Bodhgaya 菩提伽耶	2	Welcomhotel by ITC Hotels & Convention Centre
Rajgir 王舍城	1	Rajgir Residency / Indo Hoke
Vaishali 吠舍离	1	Vaishali Residency
Kushinagar 拘尸那伽	1	Royal Residency / Om Residency
Sravasti 舍卫城	1	Platinum / Sravasti Residency
Lucknow 勒克瑙	1	The Piccadilly
Agra 阿格拉	1	Grand Mercure / Clarks Shiraz

Supplements & notes 附加费与说明

- Delhi–Varanasi flight supplement: **USD 100 per person** (extra).
- Guide airfare supplement: USD 100 (extra).
- Airfare subject to change at booking; no FOC (free-of-charge seats) on airfares.
- Flight baggage: 15 kg check-in + 7 kg hand baggage 15公斤托运+7公斤手提.
- Rooms subject to availability at final confirmation.

Includes / Excludes

✓ Included	✗ Not included
------------	----------------

Twin-sharing accommodation per itinerary · 41-seater A/C coach · meals per itinerary · 1 Chinese-speaking guide · 2 bottles mineral water/person/day · monument entry (single entry)

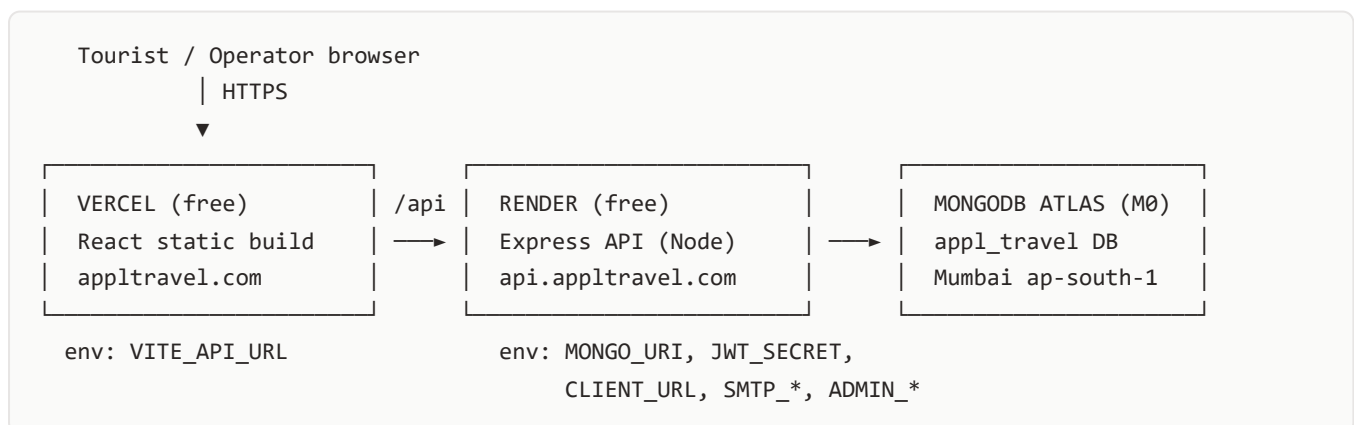
Personal expenses · tips for guide and driver · optional tours · travel insurance · international/domestic airfare (unless stated) · visa fees · anything not listed as included

Operator contact (from source documents): Astir Passage Pvt. Ltd. · tours@astirpassage.com · +91-120-4135777. The website must show these (or updated client-provided details) in the footer, contact page, and WhatsApp link. All contact details are stored in **one** frontend constant so they can be changed in a single place.

8. Non-Functional Requirements

#	Category	Requirement
NFR-1	China accessibility	Zero requests to Google-owned or China-blocked domains on public pages (fonts, maps, captcha, analytics). Sole exception: the lazily-loaded Google Sign-In button on /login and /signup, which must hide silently if unreachable (C-1, FE-12) — email+OTP remains the fully-functional path from mainland China. Verify with browser dev-tools network tab before launch.
NFR-2	Performance	First page load ≤ 3 s on 4G; production JS bundle $\leq \sim 350$ kB; images compressed and lazy-loaded when added.
NFR-3	Responsiveness	All pages usable at 360 px width; tap targets ≥ 44 px; no horizontal page scroll.
NFR-4	Security	Passwords bcrypt-hashed; JWT expires in 7 days and carries the role; every protected endpoint re-checks the role server-side (401 unauthenticated, 403 insufficient role) — UI hiding is never the security boundary; admin accounts cannot be created through the web API; secrets only in .env (never in Git); CORS restricted to the frontend origin; server re-validates all form input; HTTPS in production (automatic on Vercel/Render).
NFR-5	SEO	Bilingual meta title/description; descriptive URLs (slugs); sitemap.xml; semantic headings.
NFR-6	Reliability	Inquiry saving must not depend on email: if SMTP fails, the inquiry is still stored and visible in the dashboard.
NFR-7	Maintainability	Tour content editable in the database without code changes (seed upsert / future admin editor); contact details in one constant; all UI strings in one i18n file.

9. Deployment Architecture



- **Development:** two local processes — `server: npm run dev` (port 5000) and `client: npm run dev` (port 5173, proxies /api). Database is the same Atlas cluster (a separate `appl_travel_dev` database name may be used).
- **Launch checklist:** seed production DB → set all env vars in hosting dashboards → point custom domain to Vercel → set CLIENT_URL on Render to the final domain → replace placeholder contact details with the

client's real numbers → test the full inquiry flow end-to-end → hand over admin credentials.

- Cost at launch: ₹0 hosting + domain (~₹800–1,500/year). If China access to Vercel proves slow, Cloudflare Pages is the drop-in alternative.

10. Future Enhancements (out of scope for v1)

1. **Note:** the price/content editor, tours manager, accounts panel, and settings panel formerly listed here are **now part of the v1 scope** as role-based dashboard features (§2.5, §3.7).
2. Inquiry export (CSV/Excel) for the Owner's record-keeping.
3. "Forgot password" self-service reset (natural extension of the v1.5 OTP system: email a code, verify it, set a new password) — until then, staff passwords are reset by Admin and tourists can use Google Sign-In or contact the operator.
4. Photo galleries per tour and per sacred site (Cloudinary upload from admin panel).
5. Testimonials collection with admin moderation.
6. Destination detail pages per sacred site (SEO growth).
7. Blog / travel-guide articles (SEO growth).
8. Analytics that work in China (e.g. self-hosted Umami/Plausible).
9. Payment integration (Razorpay / bank-transfer instructions) — only if the business model changes.

— End of Document —

✿ A Journey of Wisdom, Compassion, and Enlightenment · 智慧、慈悲与觉悟之旅 ✿